

レポート: 大阪急性期・総合医療センターの事例に基づく CSIRT 構築とインシデントレスポンス検討

序論

近年、世界中でランサムウェアをはじめとするサイバー攻撃が増加しており、医療機関も例外ではありません。とくに病院は、電子カルテや検査システム、業務用ネットワークなど、患者の命を守るための重要なインフラに依存しているため、ひとたびシステム障害が起きると診療や手術の中断、救急対応の遅れなど、深刻な影響が生じます。

2022 年 10 月 31 日に大阪急性期・総合医療センターで発生したランサムウェア感染事案は、病院の基幹システムを停止させ、診療機能に大きな支障を与えました。この事件は、医療分野におけるサイバーセキュリティ体制、とりわけ CSIRT（Computer Security Incident Response Team）の重要性を改めて浮き彫りにしたと言えます。

レポートでは、同センターのインシデント調査報告書をもとに、どのような CSIRT 体制を構築すべきであったかを考察します。また、架空のインシデントケースを想定し、インシデントレスポンスの進め方や、ランサムウェアにより暗号化されたファイルの復旧方法について、その選択肢ごとのメリットとデメリットも検討します。

CHAPTER:1

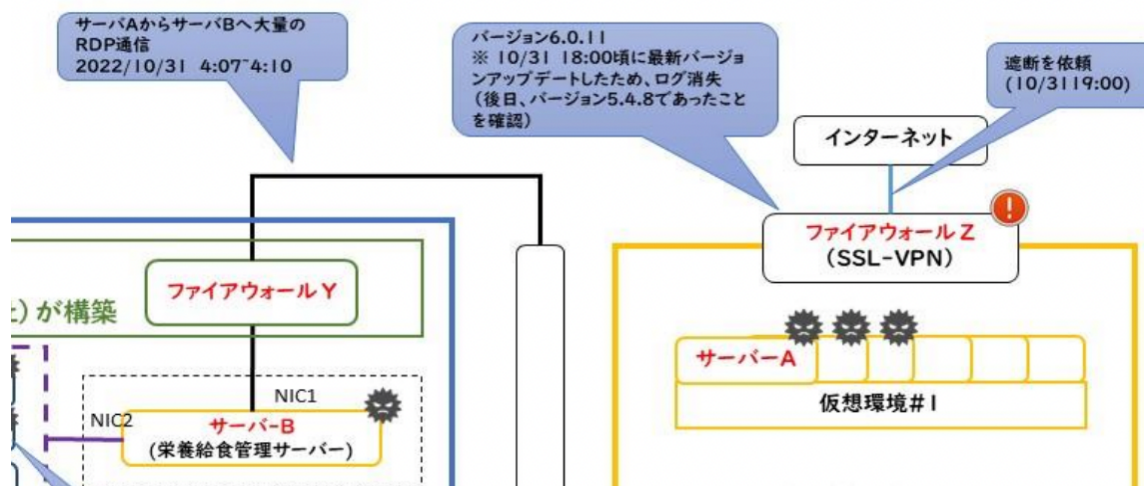
1. インシデントの背景と CSIRT の有無について

本報告書を踏まえ、今回のランサムウェア攻撃がなぜこれほど深刻な影響を及ぼしたのかについて考察する。まず、組織内に CSIRT（Computer Security Incident Response Team）が存在しなかった、または存在していても十分に機能していなかった可能性が高い。その結果、初動対応が遅れ、被害の拡大を防ぐための迅速かつ適切な対策を講じることが困難であった。

インシデントの主な原因

複数のサーバーで同一のパスワードを使用していたことが、攻撃の成功を許す大きな要因となりました。ネットワークの防御が不十分であり、RDP ポートの閉鎖やアクセス制御が適切に行われていなかったことが挙げられます。組織内に CSIRT（コンピュータセキュリティインシデント対応チーム）が設置されていなかった、あるいは設置されていても十分に機能していなかったことが被害拡大の一因となりました。

インシデントの早期発見や迅速な対応を可能にする仕組みが欠如していたことも、大きな課題として認識されます。



インシデントの概要

2022 年 10 月 31 日午前 4 時 7 分より、E 社のサーバー A から病院のネットワーク内のサーバー B へ、RDP8 /Remote Desktop Protocol/ (ポート番号 3389) を利用した接続が発生しました。サーバー B および関連する医療システムのファイルが暗号化され、身代金要求文書 (ランサムノート) が設置されました。本インシデントの発端は E 社のシステムにある可能性が示されていますが、攻撃は病院の主要なネットワークに大きな影響を与えました。被害を受けたサーバーは物理サーバーが 20 台、仮想サーバーが 100 台以上に及びました。ドメインサーバーのイベントログには、多数のログオン失敗 (イベント ID : 4625) が記録された後に、ログオン成功の記録も確認されました。

被害を受けたサーバーのパスワードおよび端末のローカル管理者アカウントのログオンパスワードはすべて共通で使用されていました。

1.現状の評価

大阪急性期・総合医療センターのインシデント報告書によると、同センターには明確な CSIRT (コンピュータセキュリティインシデント対応チーム) が設置されておらず、初動対応は主に電子カルテシステムのベンダーや外部専門家に依存していたことがわかる。このため、インシデント発生時の対応が遅れ、院内での情報共有や迅速な意思決定が困難であった可能性が高い。特に、サーバー B を中心としたランサムウェア感染が広範囲に拡大した背景には、内部の監視体制および緊急対応チームの不在が大きく影響していると考えられる。

2.理想的な CSIRT の構成

CSIRT（Computer Security Incident Response Team）は、組織の情報セキュリティインシデントに対して迅速かつ効果的に対応するための専門チームであり、その構成は多様な役割と機能を包含する必要があります。

1. マネジメント部門

この部門は CSIRT 全体の運営方針や戦略を策定し、組織の経営層と連携を取りながら資源配分や予算管理、方針の遵守を監督します。また、インシデント対応の意思決定や優先順位付けを行うため、組織のリスク管理やコンプライアンス体制とも密接に関わります。マネジメント部門のリーダーは、CSIRT の活動が組織目標に沿うよう調整し、対外的な報告や説明責任も担います。

2. テクニカル部門

テクニカル部門は実際の技術的対応を担う中核チームです。具体的には、ネットワークやシステムの監視、ログ分析、マルウェア解析、脆弱性評価、インシデントの封じ込めや原因究明、被害拡大の防止策の実施を担当します。また、復旧作業やシステムの再構築、セキュリティパッチの適用も含まれます。最新のセキュリティ技術を駆使し、インシデントを未然に防ぐための予防的活動も行います。

3. コミュニケーション部門

コミュニケーション部門は、CSIRT と外部の関係機関（厚生労働省、警察、内閣サイバーセキュリティセンター（NISC）、関連ベンダー、メディアなど）との連絡調整を担当します。迅速かつ正確な情報共有を行い、支援要請や報告を適切に行うことで、組織全体の対応力を高めます。また、インシデント発生時には広報対応も重要であり、患者や社会への影響を最小限に抑えるための説明責任を果たします。

4. 医療運営部門

医療機関特有の部門として、医療運営部門は CSIRT の一員としてインシデント対応計画（BCP：事業継続計画）を策定し、医療現場における業務継続の調整を行います。システム障害が患者ケアに与える影響を最小化し、必要に応じて手動運用への切り替えや代替措置を迅速に実施する役割を担います。医療スタッフとの連携を密にし、現場の声を CSIRT の対応に反映させることが不可欠です。

3. CSIRT の効果と期待される役割

- このような多機能かつ組織的な CSIRT が設置されていれば、今回のインシデントにおいて以下のような効果が期待できる。
- RDP の異常通信や不正ログオン試行をリアルタイムに検知し、早期にアラートを発信できる。
- サーバーB を速やかに隔離し、感染の拡大を防止する初動対応が可能となる。
- ベンダーや外部専門家だけに依存せず、院内で統合的に対応策を立案・実行できる。

- 管理者はこの異常な RDP 通信をリアルタイムで検知し、即時に対応（ブロック等）することが可能だったのか？

(現実の状況): 今回の事案では、攻撃が検知される前に既にサーバーBが侵害され、ファイルが暗号化されていた。リアルタイムの侵入検知（IDS）や自動遮断機能（IPS）が整備されていなかったため、RDP 通信を即時ブロックする対応は行われなかったと考えられる。

(私の見解では): 適切なモニタリング体制があれば、管理者はファイアウォールのポリシーを即時変更して TCP 3389 ポートを閉鎖する、または攻撃元 IP アドレスを ACL（アクセス制御リスト）で遮断することが可能だった。また、SOC（Security Operation Center）レベルの監視があれば、インシデントの初期段階で封じ込めが行えたはずであると思います。

- サーバーBが攻撃の中心となった際、ネットワーク管理者はどの段階で問題を把握できたはずなのか？

(現実の状況): 現実には、攻撃がサーバーB経由で拡大した後に初めて問題が認識され、既に 20 台以上の物理サーバーと 100 台以上の仮想サーバーが被害を受けていた。問題の初期段階（サーバーA→B への異常 RDP 接続）では可視化やアラートが行われていなかったと考えられる。

(私の見解では): サーバーBが基幹ネットワークに接続されている重要サーバーであったため、接続状況を常時モニタリングし、不審な RDP セッションを検出した時点で即座に隔離する仕組みが必要だった。もしゼロトラスト的なアクセス制御が導入されていれば、初期段階で不正アクセスを止めることができた可能性が高いと思います。

(II) RDP ポート（3389）およびその他接続チャネルの閉鎖または制限

RDP は、必要不可欠な場合のみ VPN や多要素認証で保護された環境下で利用すべきである。このポートが開放されていたことで、攻撃者が容易に侵入する足がかりを得てしまった。本来であれば、ネットワーク管理者がファイアウォールやサーバーログを通じて RDP 接続の異常な通信を監視し、疑わしいアクセスを検知した時点で即座にポートを閉鎖する、もしくは特定 IP アドレスをブロックするなどの対応が可能であったと考えられる。

(III) パスワードポリシーとアカウント管理の強化

被害を受けたサーバーや端末で共通のパスワードが使用されていた点も非常に問題であり、パスワード管理の強化が求められます。サーバーごとに異なる複雑なパスワードを設定し、定期的に変更すること、またローカル管理者アカウントのパスワードも個別管理しなければ、こうした横展開の攻撃を防ぐことは困難です。

またローカル管理者アカウントの管理を適切に行うことが求められる。

(iv) CSIRT（Computer Security Incident Response Team）が組織内に設置されており、日常的にネットワークやシステムの監視を行い、異常を早期に発見し迅速な対応ができる体制が整っていれば、被害の拡大を最小限に抑えられた可能性が高いです。このため、技術的対策のみならず、組織的な運用体制の強化も重要であると言えます。

以上のような多角的な防御策と組織体制の整備がなされていれば、本インシデントによる被害は大幅に軽減され、より迅速な復旧も可能であったと考えられます。

ランサムウェア復旧（Ransomware Recovery）

ランサムウェア復旧とは、ランサムウェア攻撃を受けた後に、コンピュータシステム、ファイル、データを復元し、身代金を支払うことなく情報へ再びアクセスし、業務活動を継続できるようにするためのプロセスです。このプロセスには、ランサムウェア感染中に破損したすべてのデータを回復すること、そして感染したシステムを特定して隔離し、ランサムウェアのさらなる拡散を防止する作業が含まれます。侵入を封じ込めた後、ランサムウェアの痕跡がシステムに残らないように、マルウェアを除去するための専門ツールを実行します。その後が始まるのが復旧フェーズであり、これは主に暗号化または損傷したファイルへのアクセスを回復することを目的とします。これには、安全で感染していないバックアップからファイルを復元する方法や、対象となるランサムウェアの復号ツール（デクリプションツール）が存在する場合にはそれを使用する方法がある。

ランサムウェアにより暗号化されたファイルを復旧する方法

1. バックアップからの復元

ランサムウェアによる被害を受けた後に、暗号化されたファイルを元に戻すための最も信頼性が高く、安全な方法は、事前に準備されたクリーンで安全なバックアップから復元を行うことである。特に、オフラインまたは隔離された環境に保管されているバックアップはランサムウェアに感染していないため、これを用いれば業務停止の時間を最小限に抑えながらシステムとデータを完全に復旧することができる。しかし、この方法が有効となるのは、平常時から適切なバックアップ計画が策定され、定期的に行われていた場合に限られるため、事前準備の重要性が強調される。

メリット:

安全かつ確実に元の状態に戻すことができる。

ランサムウェア感染前のクリーンなデータを使用するため、再感染リスクが低い。

デメリット:

事前に適切なバックアップ体制を整備していないと利用できない。

バックアップが古い場合、最新のデータが失われる可能性がある。

2. Windows システムの復元（System Restore）の活用

個人ユーザーや小規模環境では、Windows のシステム復元機能を利用して、ランサムウェア感染前の状態にシステム全体を戻す方法が考えられる。これにより、システムは感染前の設定や動作環境を取り戻すことができ、PC の使用を早期に再開することが可能となる。しかし、システム復元はあくまで OS レベルの設定や一部システムファイルの状態を戻すものであり、暗号化されてしまったユーザーファイルや業務データが必ずしも復元されるわけではないという制約があるため、限界を理解して使用する必要がある。

メリット:

感染前のシステム状態に戻すことができ、PC の早期復旧に役立つ。

ユーザーでも比較的簡単に実施可能。

デメリット:

暗号化されたファイルの復元には効果が限定的である。

すべてのファイルやアプリケーションが復元されるわけではない。

3. Windows ファイルの以前のバージョン機能の利用

Windows には、一定の条件下でファイルの“以前のバージョン”を自動保存する機能が備わっており、ランサムウェアにより暗号化されたファイルであっても、攻撃前に保存されたバージョンが残っている場合がある。この機能を使えば、暗号化前のファイルを選択的に取り出し復元することが可能となり、被害を軽減できる可能性がある。とはいえ、この機能は必ずすべてのファイルで利用できるわけではなく、また自動保存が有効になっていなければ使えないため、効果は状況に依存する点に注意が必要である。

メリット:

個別のファイルを選択的に復元できる場合がある。

ファイルの損失を部分的にでも防げる。

デメリット:

以前のバージョンが保存されていないと利用不可。

自動保存機能が無効化されている場合がある。

4. データ復旧ソフトウェアの活用

サードパーティ製のデータ復旧ソフトウェアを使用することで、ハードディスク内をスキャンし、暗号化されていない断片的なデータや上書きされていないファイルを見つけ出す試みを行うことができる。これにより、一部のファイルが部分的にでも取り戻せる可能性があるが、ランサムウェアが非常に強固な暗号化技術を使用している場合や、ディスクが既に新たなデータで上書きされている場合には、復旧の成功率が低くなることも多い。さらに、専門的なソフトウェアの導入や使用には時間とコストがかかる点も考慮しなければならない。

メリット:

一部の失われたファイルや破損していないデータを復旧できる可能性がある。

専門知識がなくても市販のツールで試せる場合が多い。

デメリット:

強力な暗号化には対応できないことが多い。

成功率が低く、時間と費用がかかる場合がある。

5. ランサムウェア専用の復号ツール (Decryption Tools) の使用

セキュリティ研究者やサイバーセキュリティ企業によって、特定のランサムウェアの暗号化方式を解析し、復号ツール (デクリプションツール) が開発されているケースがある。感染したランサムウェアの種類が特定され、暗号鍵 (decryption key) が既に解読済みである場合、これらのツールを使用することで身代金を支払わずに暗号化されたファイルを解読できる可能性がある。ただし、すべてのランサムウェアに対応するツールが存在するわけではなく、インターネット上で偽装された“偽の復号ツール”が出回っていることもあるため、正規のツールかどうかを慎重に確認する必要がある。

メリット:

身代金を支払わずにファイルを復号できる可能性がある。

セキュリティ専門家が開発した正規ツールであれば安全に使用できる。

デメリット:

すべてのランサムウェアに対応しているわけではない。

インターネット上には偽ツールも存在し、誤って使用すると更なる被害の恐れがある。

この5つの方法を比較すると、最も確実かつ安全なのはバックアップからの復元だが、事前準備が必要である。一方で、復号ツールやデータ復旧ソフトは、状況次第で効果を発揮するが、成功率や安全性には限界がある。そのため、組織や個人はランサムウェア対策として、日常的にバックアップ戦略を整備すると同時に、信頼できる情報源から最新の復旧手段を入手できる体制を構築しておくことが重要である。

<https://www.sentinelone.com/cybersecurity-101/cybersecurity/ransomware-data-recovery/>

まとめ

今回のインシデントを通じて、CSIRTの早期設置と明確な役割分担の重要性を学びました。迅速な対応体制がなければ、被害が大きく拡大することを実感しました。

また、共通パスワードの使用やネットワークの分離不足といった基本的なセキュリティ対策の不備がリスクを高めることを理解しました。

ファイル復旧では、バックアップの重要性が最も高いことを知り、普段からの定期的なバックアップの必要性を再認識しました。加えて、復号ツールやシステム復元といった多様な復旧方法があることも学びました。